

Executive Summary

In this report, 37, 3 false positives, and 10 distinct vulnerabilities were analyzed and explained in this report. What the analyst team found is that there are multiple findings that pose a real-risk to our banking infrastructure. These findings will be remediated quickly, to ensure that all known security gaps are closed to prevent a catastrophic incident from occurring.

Scope and Method

The initial scan was completed on September 8th, 2026. This type of scan is called a vulnerability scan, which maps what CVE's were found, their severity scores, and the specific vulnerability attached to it. The scan showed that thirty-seven vulnerabilities were detected. This report will cover the Top 7 vulnerabilities that pose a threat to the banks' infrastructure. Furthermore, three false-positives were listed in the scan. These will be discussed at a later point in this report.

Prioritized Findings - False Positives Removed

Rank	ID	Host	CVSS	KEV?	Impact / Notes	CVE
1	MTB-0001	MTB-WEB01	9.8	YES	Allows for RCE	CVE-2021-42013
2	MTB-0025	MTB-DC01	9.8	YES	Full control over domain / Netlogon privilege escalation	CVE-2020-1472
3	MTB-0003	MTB-WEB01	7.8	YES	Local Privilege Escalation	CVE-2021-4034
4	MTB-0002	MTB-WEB01	7.5	YES	Apache path traversal; may lead to sensitive file access and RCE under certain configurations	CVE-2021-41773
5	MTB-0014	MTB-APP01	6.5	YES	Allows code execution with elevated privileges	CVE-2023-4911
6	MTB-0009	MTB-APP01	9.8	NO	Backdoored vsftpd version may allow remote command execution	CVE-2011-2523
7	MTB-0004	MTB-WEB01	6.1	NO	XSS affecting jQuery; not in KEV	CVE-2020-11022

The prioritised findings will be described as to why they appear in a particular order. Finding number 1, appears to be a critical vulnerability that allows for Remote Code Execution (RCE) on the host MTB-WEB01. This is here because of its high score of 9.8 and its potential for damage to the bank. To fix this, the team will update Apache to the latest version. Finding number 2 includes a vulnerability that allows for control over the domain/net logon privilege escalation. This has a score of 9.8, putting it high on the list. The team will update Windows Server 2019 to the latest version. Findings number 3 and 4 allows local privilege escalation and has a score of 7.8, putting it lower than the two 9.8 scores. These emerged as the same two vulnerabilities on two different hosts, namely, web and file. Finding number 5, allows apache path traversal, which could lead to sensitive files like /etc/shadow, etc, this is ranked #4 because of its score and its potential impact. For finding

6, it shows that this vulnerability allows for privileged code execution. Finding number 7 is noticeably absent from the KEV report, therefore lowering its rank even though it has a high-severity score. Finally, finding number 8 has the lowest score of 6.1, putting it at the bottom of the list. It is also absent from the KEV report. This specific vulnerability affects a niche program instead of the whole system. These findings will be remediated and documented to ensure that all vulnerabilities have been patched.

False Positives

Three false-positives appeared on the scan. These included CVE-2014-6271, cve-2017-7494, and CVE-2019-0708. All three appeared to be critical vulnerabilities that warranted a quick remediation, however, upon further inspection, it was determined by checking the current versions of the multiple hosts, these were false positives. For CVE-2014-6271, which had a score of 9.8 and allowed for RCE, the version running on the host had a later update than the version the vulnerability affected, rendering it a false positive. For CVE-2017-7494, a vulnerability in SAMBA was discovered, however, the current version on the host was not in the affected range for this vulnerability. Finally, for CVE-2019-0708, the vulnerability affects Windows 7 and Windows Server 2008. The host is currently running Windows Server 2019. However, there was another vulnerability found that does affect Windows Server 2019, which was mentioned above.

Compensating Controls

MTB-FILE01 is running Telnet. If possible, SSH should be utilized instead.

MTB-DVWA01 - Disabled anonymous logon for FTP. Keep an eye on FTP traffic and make sure it is only used internally and disable port 21 to the internet.

MTB-WEB01 - Disable directory listing on the webserver to prevent easy enumeration + potential access

MTB-APP01 - Disable FTP

Recommended cadence

Scans should be done on a weekly basis. This is to ensure fast-discovery of recent vulnerabilities as well and swift patch management. Due to the severity of some of the recent findings, it is important to have an often-occurring scan of our infrastructure.

Section	Contents
Executive summary	Three to five sentences, plain language, no jargon.
Scope and method	Which hosts, when the scan ran, what kind of scan, how you validated.
Prioritised findings	Your re-prioritised list. Host, evidence, fix, and why it sits where it does.
False positives	Each disproved finding, what the scanner claimed, and your evidence.
Compensating controls	For anything that cannot be patched now, with a named owner and a date.
Recommended cadence	Your proposed scan frequency, with justification.